

Password Policy

Design & Implementation

Rafael Ortiz Navarro | Arnau Diaz

Professional English — CFGS ASIX/DAM | March 2026



◆ Agenda

What we will cover in this presentation

01



Why Strong Passwords Matter

Threats, risks, and consequences

02



Key Principles of Password Security

Length, complexity, uniqueness

03



Our Password Policy

Requirements, storage, schedules, incident reporting

04



Implementation & Roll-Out

Training, enforcement, ongoing maintenance

◆ Why Strong Passwords Matter

80%

of hacking-related breaches
involve stolen or weak credentials

— Verizon DBIR 2024



Credential Theft

Passwords are the #1 target for attackers worldwide



Financial Impact

Average data breach cost: \$4.88M (IBM Security, 2024)



Regulatory Risk

GDPR fines for poor access control can reach millions

Strong passwords are the foundation of authentication and access control in any organisation.

◆ Types of Password Attacks

How attackers try to break authentication systems



Brute Force

Tries every possible combination. Short passwords fall in seconds.



Phishing

Fake emails/sites trick users into giving up credentials. A social engineering technique.



Credential Stuffing

Uses leaked passwords from other breaches. Password reuse makes this deadly.



Keyloggers

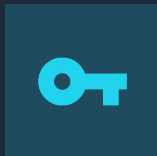
Malware records keystrokes to capture passwords as they are typed.

◆ Key Principles of Password Security



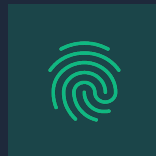
Length

Minimum 14 characters.
Longer = exponentially harder
to crack.



Complexity

Mix uppercase, lowercase,
numbers, and symbols.



Uniqueness

One password per account.
Use a password manager.



No Personal Info

No names, birthdates,
or phone numbers.

Example passphrase: **Rocket\$Lake92!Thunder** — strong AND memorable

◆ Password Policy: Creation Requirements

Rules every employee must follow when creating passwords

Requirement	Detail
Minimum Length	14 characters
Character Types	At least 3 of 4: uppercase, lowercase, numbers, symbols
No Personal Data	No names, birthdates, or identifiable information
No Common Patterns	No dictionary words alone, keyboard patterns, or sequences
No Reuse	Cannot match any of the last 10 passwords used

◆ Secure Storage & Two-Factor Authentication



For Employees

- Use the company password manager (Bitwarden)
- Protect the vault with a master password + 2FA
- Never write passwords on paper or plain text
- Never share credentials via email or chat



For IT Administrators

- Hash passwords with bcrypt or Argon2
- Apply data encryption to credential databases
- Restrict access to authorised personnel only
- Monitor logs via IDS and IPS

Two-factor authentication (2FA) is mandatory on all company accounts — authenticator app or hardware key.

◆ Password Change Schedule

Balancing security with usability — following NIST guidelines



Regular accounts

Change every 12 months



Admin / privileged

Change every 6 months



Security incident

Immediate password reset



New employee

Change on first login



Employee departure

Disable accounts within 24h

NIST no longer recommends frequent forced changes — they lead to weaker passwords (users just add "1", "2", "3").

◆ Reporting Compromised Passwords

What to do if you suspect your credentials have been exposed

1

Report

Contact IT Security via the ticketing system or hotline immediately

2

Change

Reset the password on the affected account right away

3

Don't Investigate

Let the security team handle it — they have the proper tools

4

Document

Note what happened: when, what you were doing, any suspicious links

No employee will be penalised for reporting a potential compromise. Quick reporting is more valuable than any technical measure.

◆ Implementation Plan

Rolling out the password policy across the organisation

Phase 1

Week 1-2

Preparation



- Get management approval
- Set up Bitwarden Enterprise
- Prepare training materials
- Configure system enforcement

Phase 2

Week 3-4

Communication



- Company-wide announcement
- Department training sessions
- 2FA setup assistance
- Quick-reference cards

Phase 3

Week 5+

Enforcement



- Activate system-level rules
- Mandatory resets for non-compliant
- Monitor compliance rates
- Monthly security newsletter

◆ Ongoing Maintenance

Security is not a one-time setup — it requires continuous attention



Policy review & update

Every 12 months



Phishing simulation exercises

Quarterly



Password audit

Every 6 months



Security awareness training

Annually



IDS / IPS log review

Continuous + monthly manual

◆ Key Takeaways



Long passphrases beat short complex passwords



A password manager removes the memorisation burden



Two-factor authentication is the safety net when passwords fail



Quick incident reporting is more valuable than any technical measure



Security is an ongoing process, not a one-time setup

"The strongest intrusion prevention system won't help if someone's password is Welcome123."

◆ References

- ◆ NIST SP 800-63B — Digital Identity Guidelines (2024)
- ◆ CIS Password Policy Guide — Center for Internet Security (2025)
- ◆ Cisco — Network Security Best Practices (2025)
- ◆ IBM Security — Cost of a Data Breach Report (2024)
- ◆ Verizon — Data Breach Investigations Report (2024)
- ◆ Bitwarden — Enterprise Password Management (2026)

Thank you

Rafael Ortiz Navarro & Arnau Diaz